

Ciclo de Detección de Amenazas con Threat Intelligence

Plataforma MISP · SIEM (ELK Stack) · Ejecución Controlada de Ransomware



MISP

Gabriel Gutiérrez



SIEM / ELK

Juan Malbrán



VM Víctima

Irene Alcalá



ÍNDICE

Qué vamos a ver

01

Objetivo y contexto del proyecto

02

Arquitectura general del sistema

03

Módulo 1 — Threat Intelligence con MISP

04

Módulo 2 — SIEM con ELK Stack

05

Módulo 3 — VM víctima y ejecución del malware

06

Evidencia, resultados y correlación end-to-end

07

Mapeo MITRE ATT&CK

08

Retos técnicos y conclusiones



CONTEXTO

1. Objetivo del proyecto

Construir un ciclo completo de detección de amenazas, integrando inteligencia de amenazas (Threat Intelligence), un SIEM centralizado y un endpoint real comprometido con ransomware, para observar y validar la detección de extremo a extremo.



Inteligencia

Catalogar IOCs reales del ransomware Bad Rabbit en una plataforma MISP.



Detección

Centralizar logs y correlacionar eventos en un SIEM basado en ELK Stack.



Simulación

Ejecutar el malware en un entorno aislado (entorno NAT aislado) y verificar su detección real.



ARQUITECTURA

2. Tres módulos, un mismo objetivo

Los tres equipos trabajan en máquinas independientes, interconectadas mediante una red mesh privada (Tailscale) que permite el flujo seguro de datos entre inteligencia de amenazas, detección y el endpoint comprometido.



- 1. Análisis dinámico (CAPEv2) produce IOCs de Bad Rabbit
- 2. Carga curada de IOCs en MISP, clasificados con MITRE ATT&CK
- 3. Sincronización de IOCs hacia el SIEM (ti_misp, polling 10 min)
- 4. Ejecución controlada del malware en la VM, telemetría vía Elastic Agent + Sysmon
- 5. Correlación automática: 4 reglas de detección en Kibana Security

Red mesh privada: Tailscale (tailnet malvo.musica@) · Firewall iptables restringe acceso solo a IPs autorizadas



3. Plataforma de Threat Intelligence (MISP)

Se instaló y mantuvo operativa la plataforma MISP, encargada de almacenar y catalogar la inteligencia sobre el ransomware Bad Rabbit, entregándola de forma segura al SIEM.

- **Instalación y configuración** MISP con credenciales de administrador y API Key propia
- **Carga manual de IOCs** 39 atributos del ransomware Bad Rabbit, etiquetados y clasificados con MITRE ATT&CK
- **Conexión segura** Túnel privado vía Tailscale + firewall iptables restringido a la IP del SIEM
- **Disponibilidad continua** Apache, MySQL y Redis mantenidos activos de forma permanente
- **Entrega al SIEM** IP Tailscale + API Key para la integración nativa ti_misp



Indicadores de Compromiso: Bad Rabbit

39

Atributos IOC
cargados en MISP

3

Hashes de muestra
(SHA256 · SHA1 · MD5)

13

IPs maliciosas
de C2 y payload

6

Dominios
maliciosos

90

Días de retención (IOC Expiration) tras la carga
de los 39 atributos

Tipos de indicadores registrados

- Hash SHA256, SHA1 y MD5 de BadRabbit.exe
- URLs y URIs observadas durante análisis con CAPEv2
- Archivos dropeados: dispici.exe, infpub.dat, cscd.dat
- Claves de registro de persistencia
- Tareas programadas: rhaegal, drogon
- Clasificación por Galaxies / Attack Pattern (MITRE ATT&CK)

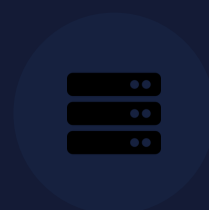


Decisión de diseño: carga manual en vez de feeds automáticos, para asegurar calidad y evitar ruido en los IOCs.



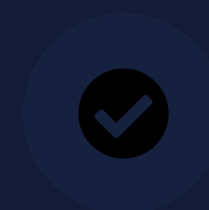
4. SIEM con ELK Stack

Se construyó el núcleo de detección del proyecto: un SIEM centralizado capaz de recibir inteligencia de MISP y telemetría real desde el endpoint víctima.



Elasticsearch

Motor de almacenamiento y búsqueda, v8.19.16



Kibana

Interfaz de visualización, gestión y Detection Engine



Logstash

Pipeline de ingesta de datos (polling cada 5 min)



Fleet Server + Elastic Agent

Gestión centralizada de sensores remotos



Del MISP al SIEM: integración ti_misp

Se evaluaron dos métodos de sincronización de IOCs. Tras descartar TAXII por problemas de certificados, se adoptó la integración oficial de Elastic para consumir IOCs directamente vía API REST.



TAXII (descartado)

- Requería instalación manual desde GitHub
- Errores de certificados SSL en producción
- Se abandonó tras las pruebas



ti_misp (adoptado)

- Integración oficial y nativa de Elastic Agent
- Usa la misma API Key generada en MISP
- Más estable y compatible con Elastic 8.x

Parámetros clave de la integración ti_misp

<code>Initial interval</code>	2160h (90 días) — ampliado para capturar eventos históricos de BadRabbit
<code>Intervalo de polling</code>	10 minutos
<code>IOC Expiration Duration</code>	90 días



Cuatro reglas de detección activas

Custom Query sobre logs-windows.* · ejecución cada 5 minutos · Kibana Security (SIEM)



Script BadRabbit en PowerShell

Critical

Risk 99



Conexión a IP maliciosa (BadRabbit / STOP Ransomware)

Critical

Risk 99



Consulta DNS a dominio malicioso

High

Risk 73



Acceso a URL maliciosa

High

Risk 73



5. VM Víctima y Ejecución Controlada del Malware

Se preparó la máquina víctima, se conectó al ecosistema del proyecto y se ejecutó de forma controlada la muestra de ransomware Bad Rabbit — generando los eventos reales que el SIEM debía detectar.



Aislamiento de red

Red NAT dedicada (SIEMLab) para contener el malware



Conexión mesh

Tailscale VPN uniendo los 4 nodos del proyecto



Telemetría de endpoint

Elastic Agent + Sysmon instalados y verificados



Ejecución controlada

Bad Rabbit ejecutado y documentado en entorno aislado



MÓDULO 3 · PREPARACIÓN

Entorno aislado: red SIEMLab

Para contener el malware de forma segura, se creó una red NAT dedicada en VirtualBox, aislando la VM víctima de la red real durante la ejecución del ransomware.

Red

SIEMLab (NAT dedicada, VirtualBox)

Prefijo IPv4

10.0.2.0/24 · DHCP habilitado

IP asignada (VM)

10.0.2.3 · gateway 10.0.2.1

Preparación del sistema

Windows Defender y Firewall desactivados para permitir la ejecución

SIEMLab · 10.0.2.0/24

Windows 10 (víctima) — 10.0.2.3

Gateway NAT — 10.0.2.1

↕ *Tailscale (túnel hacia MISP y SIEM)*

Malware contenido dentro del laboratorio



Tailscale y enrollment del Elastic Agent

La VM víctima se une a la red mesh del proyecto y se enrola contra el Fleet Server del SIEM para comenzar a enviar telemetría en tiempo real.

Tailnet del proyecto — 4 nodos conectados

gabo	100.105.34.8	Windows 11 · Integrante 1
misp	100.82.43.53	Servidor MISP · Integrante 1
nullsec	100.121.95.14	Servidor ELK · Integrante 2
windows10	100.97.37.74	VM Víctima · Integrante 3

Comando de instalación y enrollment

```
.\elastic-agent.exe install \  
  --url=https://100.121.95.14:8220 \  
  --enrollment-token=<token> --insecure
```

"Elastic Agent has been successfully installed."

Verificado además con Get-Service: Elastic Agent en estado Running.

Verificación cruzada: la tabla de nodos coincide exactamente con la documentada por el Integrante 2, confirmando la misma Tailnet del proyecto.



Sysmon: visibilidad a nivel de proceso

La integración estándar de Windows solo capturaba logs de PowerShell. Sin Sysmon, la ejecución directa de archivos .exe no queda registrada — por lo que fue una pieza clave para observar el comportamiento real del malware.

Instalación (Sysinternals v15.21)

```
.\Sysmon64.exe -accepteula -i
```

```
SysmonDrv installed. SysmonDrv started.  
Sysmon64 installed. Sysmon64 started.
```

Canales críticos habilitados

- PowerShell / PowerShell Operational
- Sysmon Operational
- Windows Defender
- AppLocker / EXE and DLL · Forwarded

Servicios en ejecución

✓ Elastic Agent	Running
✓ Sysmon64	Running

Por qué importa

Sysmon Event ID 1 (creación de proceso) y Event ID 11 (FileCreate) permitieron ver, más adelante, la ejecución exacta de BadRabbit.exe y su cifrado masivo de archivos.



MÓDULO 3 · MOMENTO CRÍTICO

Ejecución controlada de Bad Rabbit

Con la telemetría lista, se ejecutó la muestra real de BadRabbit.exe (395 KB) dentro de la VM aislada, con el único objetivo de generar eventos reales observables por el SIEM.

- 1 Descarga de la muestra en entorno controlado
- 2 Ejecución de C:\...\BadRabbit.exe en la VM aislada
- 3 Cifrado de archivos del sistema (comportamiento real)
- 4 Nota de rescate mostrada en pantalla

Consideración ética y de seguridad

Ejecución realizada exclusivamente con fines académicos, en red aislada, sin conexión a sistemas de producción ni exposición externa.

Oops! Your files have been encrypted.

**Visit our web service at
caforssztxqzf2nm.onion**

(nota de rescate completa disponible en el informe)



Comportamiento detectado por el SIEM

Búsqueda en Kibana Discover: `host.hostname:"Windows10" AND message:*BadRabbit*` → 46 documentos capturados

Línea de tiempo de eventos (Sysmon)

19:50:24	conhost.exe	Process creation
19:50:25	rundll32.exe	Process creation — carga de infpub.dat
19:50:25	BadRabbit.exe	Process terminated
19:50:36	BadRabbit.exe	Process creation
19:55:21	—	antivirus-configuration-changed

Comportamientos identificados

- Creación del proceso desde el escritorio del usuario
- Lanzamiento de rundll32.exe — técnica clásica de Bad Rabbit para cargar su DLL
- conhost.exe como subprocesso del malware
- Intento de desactivar Windows Defender
- 2,457+ eventos de PowerShell capturados, incl. bypass de políticas de ejecución



CORRELACIÓN

6. De la inteligencia a la detección: el círculo se cierra

Los tres módulos fueron verificados de forma cruzada, confirmando la integridad de los datos de extremo a extremo.



MISP

39 IOCs de Bad Rabbit
cargados y clasificados



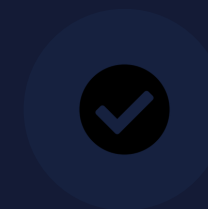
SIEM

484 eventos de amenaza
sincronizados vía ti_misp



VM Víctima

BadRabbit.exe ejecutado
y capturado por Sysmon



Detección

4 reglas activas
dispararon correctamente

Verificaciones cruzadas documentadas

- Hashes SHA256 / SHA1 / MD5 en MISP coinciden exactamente con los sincronizados en el SIEM
- Tabla de nodos Tailscale idéntica entre los informes de los 3 integrantes
- Eventos de ejecución (proceso, rundll32, antivirus) coinciden entre la VM y el SIEM



7. Mapeo MITRE ATT&CK

Técnicas MITRE ATT&CK identificadas para Bad Rabbit, según la clasificación cargada en MISP y el comportamiento observado directamente durante la ejecución controlada.

Táctica	Técnica (ID)	Evidencia en el proyecto
Defense Evasion / Execution	T1218 – Signed Binary Proxy Execution (rundll32)	rundll32.exe observado tras BadRabbit.exe (Discover)
Impact	T1485 – Data Destruction	Cifrado de archivos y nota de rescate en pantalla
Defense Evasion	T1562.001 – Impair Defenses	Evento antivirus-configuration-changed
Persistence / Priv. Escalation	T1053 – Scheduled Task/Job	Clasificación del evento en MISP (tareas rhaegal, drogon)
Credential Access	T1003 – OS Credential Dumping	Clasificación del evento en MISP (CAPEv2)

Nota: T1218 y T1562.001 surgen de evidencia observada en el laboratorio; el resto corresponde a la clasificación del evento en MISP (análisis con CAPEv2). No se ejecutó movimiento lateral real ni cifrado completo de disco.



RESULTADOS

Estado final del sistema

Elasticsearch / Kibana / Logstash Active (running)	Fleet Server + Elastic Agent Healthy
Tailscale VPN 4 peers conectados	IOCs sincronizados (ti_misp) 484 documentos
Reglas de detección 4 activas · Succeeded	Sysmon (VM víctima) Running

Índices generados en Elasticsearch

484 docs logs-ti_misp.threat-default	2,457+ docs logs-windows.powershell-default	353+ docs logs-windows.powershell_operational
--	---	---



TROUBLESHOOTING

Retos técnicos y cómo se resolvieron



Certificados SSL auto-firmados

El agente ti_misp rechazaba el certificado del MISP (x509 unknown authority)

→ `verification_mode: none`



Eventos históricos no aparecían

Initial interval de 120h insuficiente para IOCs de más de 37 días

→ `ampliado a 2160h (90 días)`



Firewall bloqueaba la Tailnet

iptables (ts-input) bloqueaba por defecto el rango 100.64.0.0/10

→ `reglas ACCEPT por IP + persistencia`



Sin visibilidad de ejecución .exe

Windows Event Log estándar no registra procesos

→ `instalación de Sysmon + canal Operational`



CIERRE

8. Conclusiones y aprendizajes

Qué logramos

● Detección end-to-end validada

Un IOC cargado manualmente en MISP terminó disparando una alerta real en el SIEM, tras la ejecución del malware correspondiente.

● Aislamiento como prioridad

Trabajar con malware real exige redes NAT dedicadas, control estricto de Firewall/Antivirus y disciplina de laboratorio.

● Telemetría de endpoint clave

Sin Sysmon, buena parte del comportamiento del ransomware habría pasado desapercibido para el SIEM.

Limitaciones y mejoras futuras

● Sin movimiento lateral real

La ejecución se limitó a un único host aislado; no se evaluó la propagación real (EternalRomance/SMB, Mimikatz).

● Detección únicamente pasiva

No se incorporó un SOAR: falta automatizar la respuesta ante alertas críticas.

● Carga de IOCs manual

Mejora futura: sumar feeds automáticos de MISP y un segundo host víctima para ampliar cobertura.



Trabajo en equipo distribuido

Tailscale permitió coordinar 3 máquinas en redes distintas como si fueran una sola infraestructura.



Gracias

Ciclo de Detección de Amenazas con Threat Intelligence — Grupo Nullsec